



Introducción al Marco Legal y Auditorías de Ciberseguridad



Con la colaboración:





RGPD – Reglamento General de Protección de Datos

Módulo 4

RGPD – Reglamento General de Protección de Datos

Introducción general

- El **RGPD (GDPR)** es el reglamento europeo que regula la protección de los datos personales en la Unión Europea y el Espacio Económico Europeo. Entró en vigor el **25 de mayo de 2018**, sustituyendo la Directiva 95/46/CE. Aporta un marco unificado de protección de datos para todos los Estados miembros, con **requisitos exigibles a nivel organizativo, técnico, documental y ético**.

¿A quién se aplica?

- **A. Ámbito territorial:**
 - Todas las organizaciones **dentro de la UE** que traten datos personales.
 - También **organizaciones fuera de la UE** que traten datos de ciudadanos europeos (por ejemplo, empresas tecnológicas de EE.UU.).
- **B. Ámbito material:**
 - Toda actividad que implique el **tratamiento de datos personales**, de forma automatizada o no (papel, archivos físicos, etc.).

RGPD – Reglamento General de Protección de Datos

Principios fundamentales del RGPD

- Principios fundamentales del RGPD
- Licitud, lealtad y transparencia
- Limitación de la finalidad
- Minimización de datos
- Exactitud
- Limitación del plazo de conservación
- Integridad y confidencialidad
- Responsabilidad proactiva (“Accountability”)

RGPD – Reglamento General de Protección de Datos

¿Qué son los datos personales?

- Cualquier información sobre una persona **identificada o identificable**:
- Nombres, DNI, teléfono, email, etc.
- Datos de salud, orientación sexual, datos biométricos.
- Ubicación, identificadores en línea, hábitos de consumo.

PII – “Personally Identifiable Information”

(en español: **Información de Identificación Personal**)

Tipo de dato	Nivel	Ejemplo
Datos básicos	Bajo	Nombre, email, dirección postal
Datos financieros	Medio	IBAN, tarjeta bancaria
Datos sensibles	Alto	Salud, afiliación sindical, creencias, etc.
Datos especialmente protegidos	Muy alto	Genéticos, biométricos, menores, penales

RGPD – Reglamento General de Protección de Datos

Ciclo de vida de los datos personales

- Recogida / Captura
- Almacenamiento / Tratamiento
- Acceso / Consulta
- Cesión / Transferencia
- Conservación / Archivo
- Supresión / Bloqueo / Eliminación

RGPD – Reglamento General de Protección de Datos

Roles clave en este ciclo

Rol	Función principal	Responsabilidades clave
Interesado (Data Subject)	Persona titular de los datos personales.	Ejercer sus derechos: acceso, rectificación, supresión, portabilidad, etc.
Responsable del Tratamiento (Controller)	Decide el propósito y medios del tratamiento.	- Define políticas de privacidad y consentimiento.- Garantiza cumplimiento del RGPD.- Notifica brechas de seguridad.
Encargado del Tratamiento (Processor)	Trata datos por cuenta del responsable.	- Aplica medidas técnicas y organizativas.- No decide fines ni medios.- Colabora ante auditorías o brechas.
Delegado de Protección de Datos (DPO)	Asesor y supervisor independiente.	- Vigila el cumplimiento del RGPD.- Punto de contacto con la AEPD.- Informa y forma al personal.
Autoridad de control (AEPD / Supervisory Authority)	Organismo público nacional o europeo.	- Supervisa, asesora y sanciona.- Recibe notificaciones de brechas.- Resuelve reclamaciones.
Terceros receptores (destinatarios)	Entidades que reciben datos (proveedores, socios, autoridades).	- Solo tratan datos si es legal y con base jurídica adecuada.
Corresponsable del Tratamiento (Joint Controller)	Dos o más entidades comparten responsabilidad.	- Deben definir funciones y responsabilidades conjuntas por contrato.
Usuarios internos / empleados	Acceden a los datos dentro de la organización.	- Solo pueden tratar datos conforme a instrucciones del responsable.- Deben recibir formación.

RGPD – Reglamento General de Protección de Datos

Modelo de roles en una organización

Ejemplo práctico para un hospital:

Área	Rol
Dirección	Responsable del tratamiento
Proveedor de software	Encargado del tratamiento
Paciente	Interesado
DPO	Supervisor del cumplimiento
RRHH	Corresponsable (según actividad)

RGPD – Reglamento General de Protección de Datos

Derechos del interesado

- Acceso
- Rectificación
- Supresión (“derecho al olvido”)
- Oposición
- Portabilidad
- Limitación del tratamiento
- No ser objeto de decisiones automatizadas

Obligaciones para las organizaciones

- Elaborar un **registro de actividades de tratamiento**
- Implementar medidas de **seguridad técnicas y organizativas**
- Establecer políticas de privacidad y cookies
- Evaluar el impacto en la privacidad (EIPD) si el tratamiento implica **alto riesgo**
- Documentar y notificar **brechas de seguridad en 72h**

RGPD – Reglamento General de Protección de Datos

Relación con la AEPD y otras entidades

AEPD – Agencia Española de Protección de Datos

- Es la autoridad de control nacional.
- Emite guías, resoluciones, sanciona y asesora.
- Canal de notificación de brechas: <https://notifica.aepd.es>

Coordinación europea:

- A través del **European Data Protection Board (EDPB)**.
- Marco común con otras autoridades de protección de datos (CNIL, BfDI, etc.)

RGPD – Reglamento General de Protección de Datos

Factores de éxito en la implantación del RGPD

- ✓ Apoyo visible de la alta dirección
- ✓ Implicación del área legal, IT y negocio
- ✓ Formación continua de empleados
- ✓ Políticas claras y sencillas
- ✓ Seguridad por diseño y por defecto
- ✓ Gestión adecuada de proveedores

RGPD – Reglamento General de Protección de Datos

Sanciones y consecuencias

Tipos de infracciones:

Infracción	Ejemplo	Sanción máxima
Grave	No informar al interesado	10 M € o 2% de facturación
Muy grave	Tratar sin consentimiento	20 M € o 4% de facturación

Casos reales:

- Google (50 M € – CNIL, Francia)
- British Airways (20 M £ – ICO, Reino Unido)
- AEPD (Multas a empresas por envío masivo de correos, videovigilancia sin aviso, etc.)

RGPD – Reglamento General de Protección de Datos

RGPD y su impacto en entornos OT

Aunque tradicionalmente el RGPD se asocia con IT, cada vez es más relevante en **entornos industriales y OT**, donde se capturan datos personales indirectamente:

- **Controles de acceso a planta (biometría, CCTV)**
- **Sistemas SCADA con usuarios identificados**
- **Trazabilidad de operarios**

Se debe asegurar que el cumplimiento del RGPD no interfiera con la operación crítica, pero que sí garantice privacidad y control.

RGPD – Reglamento General de Protección de Datos

Relación con otras normativas

Norma / Regulación	Relación con RGPD
ENS (España)	Define medidas de seguridad aplicables al tratamiento de datos públicos
ISO/IEC 27001	Ayuda a implementar controles técnicos/organizativos
ISO/IEC 27701	Complemento específico de privacidad
NIS2	Cubre seguridad de redes/sistemas, pero también exige protección de datos
DORA	Aplica en sector financiero, alineado con RGPD en términos de brechas y terceros

RGPD – Reglamento General de Protección de Datos

Cómo se implementa el RGPD (en la práctica)

Etapas recomendadas:

- **Análisis de situación inicial**
 - Inventario de tratamientos y flujos de datos
- **Evaluación legal y técnica**
 - ¿Se necesita consentimiento? ¿Hay base legítima?
- **Implantación de medidas**
 - Políticas, formación, seguridad IT/OT
- **Documentación**
 - Registro de tratamientos, contratos con encargados
- **Revisión periódica y auditoría**
 - Interna o externa

RGPD – Reglamento General de Protección de Datos

Cómo se implementa el RGPD (en la práctica)

Herramientas útiles:

- ISO/IEC 27701 (extensión de privacidad sobre ISO 27001)
- ENS (Esquema Nacional de Seguridad)
- NIST Privacy Framework
- GDPR Toolkit (ENISA)

RGPD y la transferencia de datos personales a terceros países

¿Por qué es un tema crítico?

El RGPD exige que los datos personales de ciudadanos de la UE **no salgan del Espacio Económico Europeo (EEE)** salvo que se garantice **un nivel adecuado de protección**. Esto afecta directamente al uso de **proveedores de nube** cuyos servidores o empresas matrices están **fuera de la UE**, como ocurre con muchos servicios cloud.

¿Qué considera el RGPD una "transferencia internacional de datos"?

- Cualquier acceso, almacenamiento o procesamiento de datos personales **fuera del EEE**, o incluso dentro del EEE **por parte de una entidad controlada desde fuera**, se considera transferencia internacional.
- Por ejemplo: usar un CRM en la nube que almacena backups en servidores de EE. UU., aunque la interfaz esté en Europa.

RGPD y la transferencia de datos personales a terceros países

¿Qué exige el RGPD para que esa transferencia sea legal?

A. Decisión de adecuación (Artículo 45 RGPD)

- La Comisión Europea determina si un país **garantiza un nivel adecuado de protección**.
- Si es así, **se puede transferir libremente** sin garantías adicionales.
- **Países con adecuación:** Reino Unido, Suiza, Canadá (solo comerciales), Japón, Corea del Sur, Israel, entre otros.

B. Garantías adecuadas (Artículo 46)

- Si no hay adecuación, se pueden usar mecanismos legales:
- **Cláusulas Contractuales Tipo (SCCs)** → contrato aprobado por la Comisión.
- **Normas corporativas vinculantes (BCRs)** → para multinacionales.
- **Certificaciones y códigos de conducta** (en evolución).

C. Excepciones (Artículo 49)

- Para casos puntuales: consentimiento explícito, contrato en interés del interesado, interés público, etc.
 No se deben usar como solución habitual.

RGPD y la transferencia de datos personales a terceros países

Casos prácticos

GB Reino Unido (UK)

Tras el Brexit, **Reino Unido es un "tercer país"**.

- Pero en 2021, la Comisión Europea le otorgó **decisión de adecuación**, por lo que las transferencias son válidas **sin medidas adicionales**.
- Esto se revisará cada 4 años (próxima revisión en 2025).
- Se puede usar Microsoft UK, AWS UK, etc., sin SCCs adicionales por ahora.

RGPD y la transferencia de datos personales a terceros países

Casos prácticos

US Estados Unidos

- En 2020, el **TJUE invalidó el acuerdo Privacy Shield** (caso "Schrems II") por permitir vigilancia masiva de EE.UU. (FISA 702, EO 12333).
- Esto implicó que **toda transferencia a EE.UU. requiere garantías adicionales** (normalmente SCCs).

Solución reciente: Data Privacy Framework (DPF) – julio 2023

- Acuerdo UE-EE.UU. que **restablece la adecuación** para empresas estadounidenses **certificadas** en el DPF.
- Lista de empresas certificadas: <https://www.dataprivacyframework.gov>
- Se puede usar legalmente **Google, Microsoft, AWS**, si están en la lista DPF.
- Pero sigue siendo recomendable aplicar medidas complementarias (cifrado, pseudonimización, etc.) si los datos son sensibles.

RGPD y la transferencia de datos personales a terceros países

¿Cómo se puede gestionar legalmente?

Paso a paso para cumplir:

- **Identificar todos los servicios cloud usados** (incluso backups, soporte remoto, etc.)
- **Revisar dónde están los datos físicamente alojados.**
- **Determinar si el país tiene decisión de adecuación.**
- Si no, aplicar **SCCs actualizadas** con análisis de impacto (Transfer Impact Assessment).
- En caso de servicios en EE. UU., **verificar si están certificados en el DPF.**
- Aplicar medidas técnicas: **cifrado, segmentación, control de acceso.**
- Documentar todo en el **Registro de Actividades de Tratamiento** y el **contrato con el encargado.**

RGPD y la transferencia de datos personales a terceros países

¿Cómo se puede gestionar legalmente?

Recomendaciones para organizaciones

- Preferir **proveedores europeos o con centros de datos en la UE** si el tratamiento es sensible.
- Incluir cláusulas específicas sobre cumplimiento RGPD en los contratos cloud.
- Consultar con el **DPO** antes de transferir datos fuera del EEE.
- No usar **servicios gratuitos no auditados** para gestionar datos personales.

RGPD y la transferencia de datos personales a terceros países

Resumen visual de varios ejemplos

País	Nivel legal	¿Se puede transferir?	Medidas adicionales
Alemania	UE	Sí	No
Reino Unido	Adecuación	Sí	No
EE. UU. (certificado DPF)	Parcial	Sí	Recomendable cifrado
EE. UU. (sin DPF)	No	Solo con SCCs + evaluación	Sí
China, Rusia	No	Muy restringido	No recomendable